

Exercício 9 — Relação entre CWE, CVE e CVSS

Discuta a relação entre CWE, CVE e CVSS.

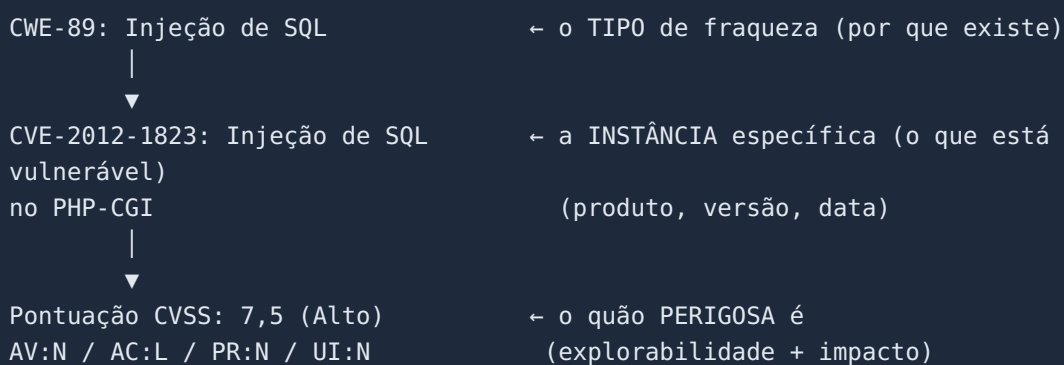
Como esses frameworks podem trabalhar juntos para aprimorar a estratégia de gerenciamento de vulnerabilidades de uma organização?

9. Relação entre CWE, CVE e CVSS

Os Três Frameworks — Uma Frase Cada

- **CWE** — descreve o *tipo de fraqueza* no código (a causa raiz)
- **CVE** — identifica uma *vulnerabilidade específica* em um produto específico (o incidente)
- **CVSS** — mede o *quão grave* é essa vulnerabilidade (a pontuação)

Como Eles Se Conectam



O CWE explica a **causa**. O CVE nomeia o **evento**. O CVSS mede o **risco**.

Uma Analogia do Mundo Real

Pense em um relatório de acidente de trânsito:

Framework	Analogia
CWE	A estrada não tinha grade de proteção (falha de design — causa raiz)
CVE	Em 5 de março, um carro caiu da Rodovia 9 no km 42 (incidente específico)
CVSS	O acidente causou 3 mortes e bloqueou o tráfego por 6 horas (pontuação de severidade)

Cada camada adiciona uma dimensão diferente de compreensão.

Como Trabalham Juntos no Gerenciamento de Vulnerabilidades

Passo 1 — Scanner detecta um CVE

Um scanner de vulnerabilidades encontra o **CVE-2021-44228** (Log4Shell) em um servidor.

Passo 2 — CVSS diz o quão urgente é

Pontuação CVSS: **10,0 — Crítico** → Pare tudo. Aplique o patch agora.

Passo 3 — CWE diz por que aconteceu

CWE-502: Desserialização de Dados Não Confiáveis → A causa raiz é que a aplicação confiou cegamente em dados externos. → Pesquise em todo o código base por padrões semelhantes.

Passo 4 — Corrija a instância E a causa raiz

Curto prazo → Corrigir o CVE (aplicar atualização do Log4j)
Longo prazo → Eliminar o padrão CWE em todos os projetos

Treinar desenvolvedores em CWE-502
Adicionar regra SAST para detectá-lo no CI/CD

A Estratégia Completa

Framework	Papel na Estratégia	Quem Usa
CWE	Previne que vulnerabilidades sejam criadas	Desenvolvedores, arquitetos
CVE	Identifica o que precisa ser corrigido agora	Operações de segurança, sysadmins
CVSS	Determina a ordem de remediação	Gestores de segurança, equipes de risco

Por que Você Precisa dos Três

- **CVSS sem CVE** → você tem uma pontuação, mas não sabe o que corrigir
- **CVE sem CVSS** → você sabe o que está quebrado, mas não o quão urgente é
- **CVE sem CWE** → você corrige a instância, mas escreve a mesma falha novamente na próxima sprint
- **Os três juntos** → você corrige rapidamente, prioriza corretamente e previne recorrência

Resumo

*CWE, CVE e CVSS não são frameworks concorrentes — são **camadas da mesma resposta**. CWE previne. CVE identifica. CVSS prioriza. Uma organização que usa os três não apenas reage a vulnerabilidades — ela reduz sistematicamente a chance de criá-las.*